

IMPLEMENTACIÓN Y HARDENING DE SEGURIDAD CORREO Y AUTENTICACIÓN DE DOMINIO (SPF, DKIM Y DMARC) EN PLATAFORMAS DE CORREO CLOUD

Autor: **SYSARMOR TECH**

Enfoque: Ciberseguridad Enterprise, Identidad, Infraestructura Cloud y Protección de Mensajería

1. INTRODUCCIÓN Y CONTEXTO OPERATIVO

En el ecosistema de ciberseguridad moderno, el correo electrónico continúa siendo el vector primario de ataque para campañas de *Phishing*, suplantación de identidad (*Domain Spoofing*) y compromiso de cuentas empresariales (BEC Business Email Compromise). La falta de validación criptográfica y directivas de alineación en un dominio corporativo permite a ciberdelincuentes forjar cabeceras SMTP y enviar mensajes fraudulentos a nombre de la organización.

Este documento establece el procedimiento técnico formal de SysArmor Tech para auditar, diseñar e implementar una arquitectura tripartita de autenticación de mensajes utilizando SPF (Sender Policy Framework), DKIM (DomainKeys Identified Mail) y DMARC (Domain-based Message Authentication, Reporting, and Conformance). El objetivo es llevar la directiva de dominio desde una postura inicial de monitoreo hasta el bloqueo absoluto en el borde (p=reject), blindando la reputación del dominio corporativo.

2. OBJETIVOS TÉCNICOS

- Diseñar y publicar un registro SPF optimizado que cumpla con el límite de 10 búsquedas DNS (*DNS Lookups*) y aplique el calificador estricto de rechazo (-all).
- Habilitar la firma criptográfica asimétrica DKIM mediante la creación, publicación y validación de selectores CNAME en la zona DNS pública.
- Estructurar un despliegue progresivo de políticas DMARC divididas en tres fases de madurez: monitoreo (p=none), aislamiento (p=quarantine) y bloqueo total (p=reject).
- Establecer un procedimiento de inspección profunda de cabeceras crudas (Header Alignment) para certificar la correspondencia estricta entre el remitente visible y los mecanismos de autenticación subyacentes.

3. REQUISITOS PREVIOS Y ENTORNO DE TRABAJO

Componente	Requisito Técnico / Estándar	Función en la Metodología
Plataforma de Correo	Servicio de mensajería cloud (ej. Microsoft 365 / Exchange Online)	Procesamiento de correo saliente/entrante y generación de llaves de firma criptográfica DKIM.
Dominio Corporativo	Dominio propio activo (ej. sysarmortech.com)	Zona DNS pública objetivo para la inserción de registros TXT y CNAME.
Acceso a Zona DNS	Consola de administración con permisos de edición (ej. Cloudflare, Spaceship, GoDaddy)	Aprovisionamiento y control de registros SPF, CNAMEs de DKIM y directiva DMARC.
Cliente de Auditoría	Consola PowerShell / Módulo de gestión y herramientas web	Validación de registros en propagación y análisis forense de cabeceras.

4. ARQUITECTURA DE AUTENTICACIÓN Y ALINEACIÓN DE CORREO

Mecanismo	Tipo de Registro DNS	Función Primaria	Criterio de Alineación DMARC
SPF	TXT	Especifica las direcciones IP o servicios autorizados para remitir correo a nombre del dominio.	El dominio en la cabecera Return-Path (o MAIL FROM) debe coincidir con el dominio Header.From.
DKIM	CNAME (Apuntando a llaves públicas de M365)	Añade una firma digital criptográfica no repudiable en la cabecera del correo para garantizar la integridad.	El dominio en la etiqueta d= de la cabecera DKIM-Signature debe coincidir con el dominio Header.From.
DMARC	TXT en _dmarc.dominio.com	Define las instrucciones para el servidor receptor cuando un correo no cumple la alineación SPF o DKIM.	Requiere que al menos un mecanismo (SPF o DKIM) pase la verificación Y mantenga la alineación del dominio.

5. PROCEDIMIENTO TÉCNICO PASO A PASO (CHECKLIST DE HARDENING)

Paso 1: Hardening e Implementación del Registro SPF (Sender Policy Framework)

El registro SPF es un tipo de registro TXT del DNS que indica de forma explícita qué servidores de correo y bloques de direcciones IP están autorizados para transmitir correos electrónicos en nombre de un dominio específico.

1. Acceda a la consola de administración de su proveedor DNS público.
2. Cree o edite el registro tipo TXT ubicado en la raíz del dominio (@).
3. Configure el valor estructurado autorizando exclusivamente a los servidores de la plataforma de correo autorizados (ejemplo para Microsoft 365):

```
v=spf1 include:spf.protection.outlook.com -all
```

Nota técnica: Hardening (SysArmor Tech):

- Sintaxis estricta: Asegúrese de que el registro comience estrictamente con v=spf1 y termine con el calificador de rechazo –all o ~all
- Límite de consultas DNS: El árbol de resolución no debe superar las 10 consultas recursivas para evitar errores de validación (permerror) según el RFC 7208.
- Calificador de fallo: Se fuerza el uso de -all (Hard Fail) en sustitución de ~all (Soft Fail) para instruir de forma mandataria a las pasarelas receptoras que desechen cualquier origen no declarado.
- validar con herramientas como DMARC Report, Sendmarc o PowerDMARC para detectar errores de sintaxis y exceso de consultas DNS

Paso 2: Generación, Publicación y Activación de DKIM

Los sistemas de correo modernos requieren la implementación de dos selectores rotativos para garantizar la firma criptográfica continua del tráfico saliente sin interrupciones durante la rotación de llaves.

1. Identifique los nombres de los selectores asignados por el tenant de correo (generalmente selector1 y selector2).
2. Diríjase a la zona DNS pública y publique dos registros tipo CNAME apuntando a los objetivos provistos por la plataforma:

Nombre Subdominio	Tipo	Valor / Destino Target
selector1._domainkey	CNAME	selector1-sysarmortech-com._domainkey.tenant.onmicrosoft.com
selector2._domainkey	CNAME	selector2-sysarmortech-com._domainkey.tenant.onmicrosoft.com

Una vez confirmada la propagación correcta de los registros CNAME en el DNS, ejecute la activación del firmado criptográfico mediante la consola de automatización (ejemplo mediante PowerShell con Exchange Online):

```
Connect-ExchangeOnline -UserPrincipalName admin@sysarmortech.com  
New-DkimSigningConfig -DomainName "sysarmortech.com" -Enabled $true
```

Nota técnica: Cada dominio debe tener al menos una clave pública activa en DNS y se recomienda rotar claves periódicamente y usar longitudes de 2048 bits.

Paso 3: Despliegue Progresivo de la Política DMARC

Para mitigar riesgos de interrupción operativa o falsos positivos en flujos de negocio legítimos, la directiva DMARC debe transicionar obligatoriamente a través de tres fases controladas de madurez en la zona DNS (`_dmarc.dominio.com`):

Fase 3.1: Fase de Monitoreo y Auditoría (`p=none`)

Permite recolectar reportes agregados XML (RUA) para identificar fuentes de envío legítimas o desalineadas sin afectar la entrega del correo:

```
v=DMARC1; p=none; rua=mailto:dmarc-reports@sysarmortech.com; pct=100; sp=none; adkim=r; aspf=r;
```

Fase 3.2: Fase de Aislamiento Progresivo (`p=quarantine`)

Una vez auditadas y corregidas todas las fuentes corporativas, se fuerza el aislamiento de mensajes no autenticados directamente hacia la bandeja de correo no deseado (*Spam/Junk*):

```
v=DMARC1; p=quarantine; pct=100; rua=mailto:dmarc-reports@sysarmortech.com; ruf=mailto:dmarc-failures@sysarmortech.com; sp=quarantine;
```

Fase 3.3: Fase de Enforcement y Hardening Total (`p=reject`)

Estado final de máxima seguridad Enterprise. Las pasarelas receptoras tienen la orden explícita de descartar en el borde (*SMTP drop*) cualquier intento de suplantación sobre el dominio corporativo:

```
v=DMARC1; p=reject; pct=100; rua=mailto:dmarc-reports@sysarmortech.com; ruf=mailto:dmarc-failures@sysarmortech.com; sp=reject; adkim=s; aspf=s;
```

6. MATRIZ DE CONFIGURACIÓN Y PARÁMETROS DMARC

Etiqueta / Tag	Función Técnica	Valores Recomendados (Producción Hardened)
v	Identificador de versión del protocolo DMARC.	DMARC1
p	Directiva impuesta al dominio principal (none, quarantine, reject).	reject
sp	Directiva aplicada específicamente a los subdominios.	reject
rua	Dirección URI para la recepción de reportes agregados XML de diagnóstico.	mailto:dmarc-reports@dominio.com
pct	Porcentaje de mensajes sospechosos filtrados por la directiva (1 - 100).	100
adkim / aspf	Modo de alineación (r = Relajado, s = Estricto) para DKIM y SPF.	s (Estricto) o r (Relajado segun requerimientos)

Nota técnica:

- ✓ Se sugiere iniciar con none para monitoreo y luego escalar a reject, también habilitar reportes agregados (rua) y forenses (ruf)

7. VERIFICACIÓN, AUDITORÍA Y TRAZABILIDAD

Para certificar el éxito de la implementación y validar la correcta resolución de los registros de infraestructura, ejecute las siguientes verificaciones operativas de nivel técnico:

7.1. Validación Automatizada mediante PowerShell

Ejecute los siguientes cmdlets de resolución DNS para comprobar la salud de los registros publicados:

1. Validar la existencia y sintaxis del registro SPF

```
Resolve-DnsName -Name "sysarmortech.com" -Type TXT | Where-Object Strings -like "*v=spf1*"
```

2. Validar la correcta resolución de los selectores DKIM CNAME

```
Resolve-DnsName -Name "selector1._domainkey.sysarmortech.com" -Type CNAME
```

```
Resolve-DnsName -Name "selector2._domainkey.sysarmortech.com" -Type CNAME
```

3. Validar la directiva DMARC activa en el subdominio de control

```
Resolve-DnsName -Name "_dmarc.sysarmortech.com" -Type TXT
```

7.2. Validación desde PowerShell

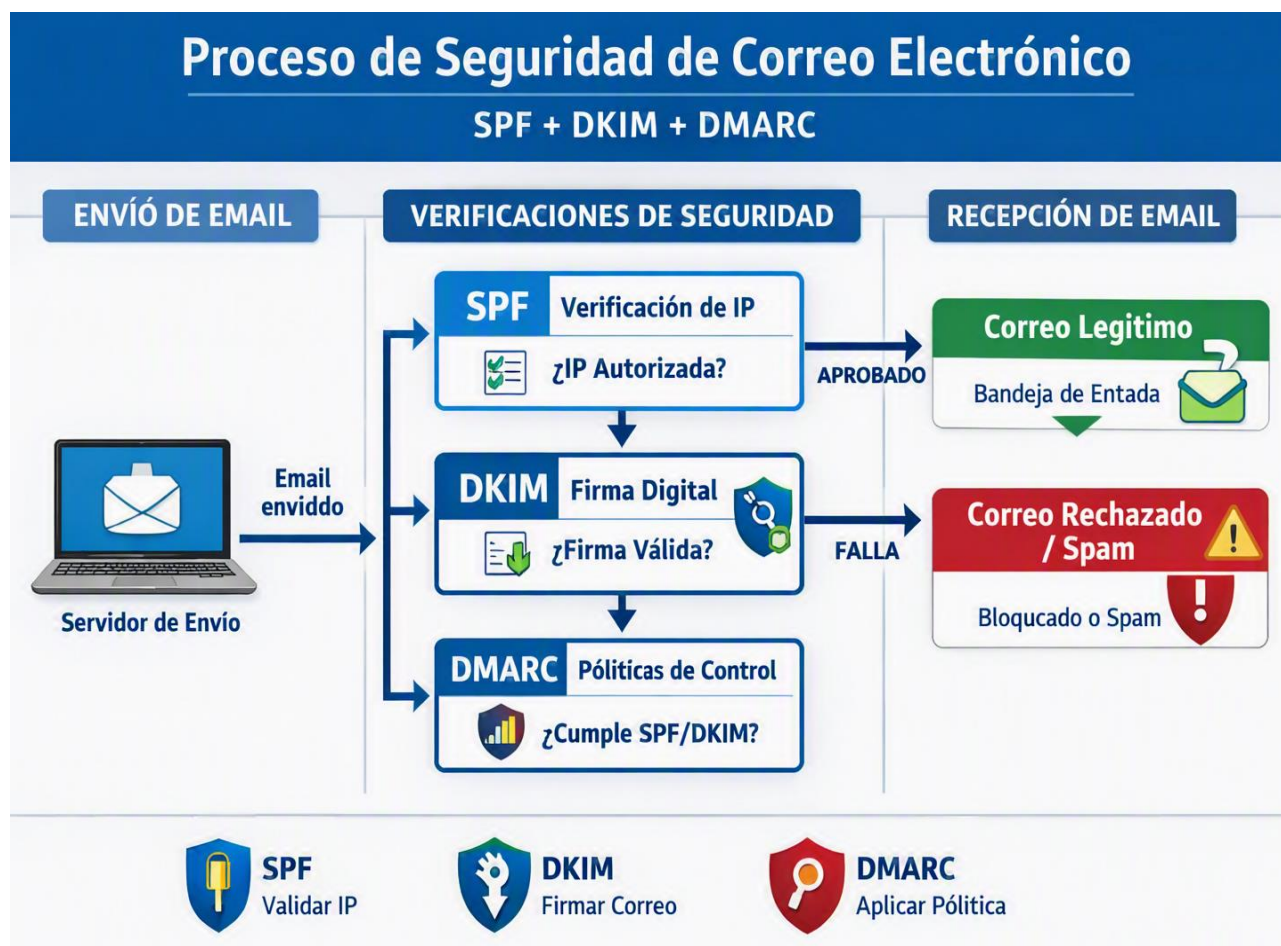
Envíe un correo electrónico hacia una cuenta externa de control (ej. Gmail o buzones independientes) y analice el bloque Authentication-Results en el código fuente del mensaje (*Internet Headers*), el cual debe arrojar el siguiente resultado óptimo:

```
Authentication-Results: spf=pass (sender IP is X.X.X.X)  
smtp.mailfrom=sysarmortech.com;
```

```
                dmarc=pass (p=REJECT sp=REJECT dis=NONE)  
header.from=sysarmortech.com;
```

```
                dkim=pass (signature verified) header.d=sysarmortech.com;
```

8. Resumen del flujo de autenticación de correo.



Recomendaciones:

- ✓ Limitar el número de proveedores externos que envían en nombre del dominio.
- ✓ Revisar periódicamente los registros DNS para evitar configuraciones obsoletas.
- ✓ Documentar internamente qué servicios están autorizados para enviar correo.

En **SysArmor Tech**, esta guía y su implementación se construyen bajo principios de arquitectura robusta, automatización y seguridad por diseño. Cada laboratorio busca resolver problemáticas complejas de infraestructura de nivel 2 y 3, priorizando el uso de estándares limpios y mantenibles.

Al tratarse de un espacio de divulgación e ingeniería personal, este documento se comparte como un recurso de referencia técnica abierta. Te invito a explorar los demás artículos del sitio, utilizar las herramientas interactivas disponibles y conectar a nivel profesional a través de LinkedIn.